PROGRAMA AVANZADO · BLOQUE I — CIBERSEGURIDAD

MÓDULO 4 · DATO

Ciberseguridad del Dato y Tecnologías Disruptivas

Data · Identity · Trust · Escenario: Telvora Communications

Duración del módulo: 7 h (3 sesiones) · Dato · Criptografía · PKI/TLS · Identidad · Cloud · IoT

Los cinco bloques del módulo

A	**El dato**	Contexto, ciclo de vida, clasificación que produce controles y DLP contextual
B	**Criptografía, claves y confianza**	Propiedades cripto, gestión de claves, PKI/X.509 y TLS 1.3
C	**Identidad y accesos**	IAM humano y de máquina, MFA, SAML/OAuth/OIDC, PAM y ZSP
D	**Secretos y nube**	Secrets lifecycle, workload identity, responsabilidad compartida, CSPM/CNAPP
E	**IoT y confianza**	MQTT, modelo de amenaza y modelo de confianza de dispositivos

BLOQUE A



El dato

Contexto · ciclo de vida · clasificación que produce controles · DLP contextual

El mismo fichero, riesgos opuestos



customer-list.csv

Solo identificadores técnicos, sin relación con una persona.

Riesgo bajo



customer-list.csv

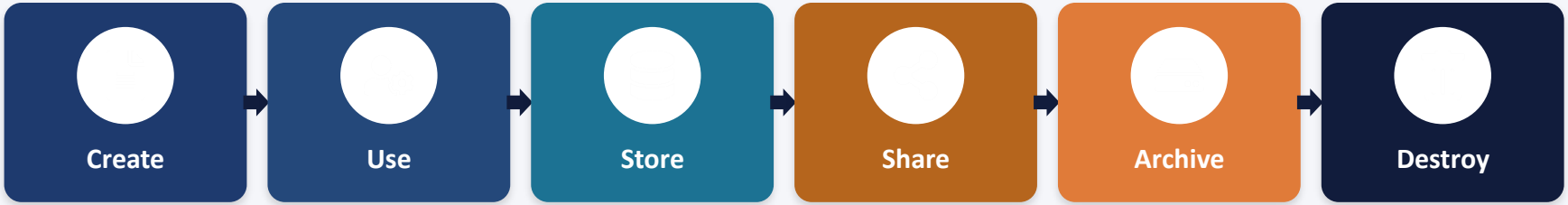
Nombre, DNI, teléfono, ubicación, credenciales, histórico de consumo, contrato.

Riesgo crítico



La protección no se define por la extensión del fichero.
Se define por su contenido, uso, sensibilidad, obligaciones y consecuencias de compromiso. Y en telco, la integridad de la configuración, el routing o los inventarios puede ser MÁS crítica que su confidencialidad: «secreto» no es solo «oculto».

El dato vive en fases — y no muere al «borrarlo»



En cada fase: owner · base legal · quién accede · dónde se copia · cuánto se conserva · cómo se destruye.

Borrar en la aplicación ≠ desaparición inmediata del dato.

backups · réplicas · data lakes · caches · logs · snapshots · endpoints

La copia que olvidas es la que te filtran.

Una etiqueta solo sirve si activa un control

PUBLIC	Puede publicarse; la integridad sigue siendo crítica.
INTERNAL	Acceso autenticado; sharing externo controlado.
CONFIDENTIAL	Cifrado, acceso mínimo, logging reforzado.
RESTRICTED	Acceso privilegiado/JIT, controles de exfiltración, custodia reforzada.

Clasifica por C·I·D, privacidad, impacto contractual/regulatorio, valor operacional y longevidad — el nombre importa menos que el efecto técnico.

Detectar un patrón no es comprender el riesgo

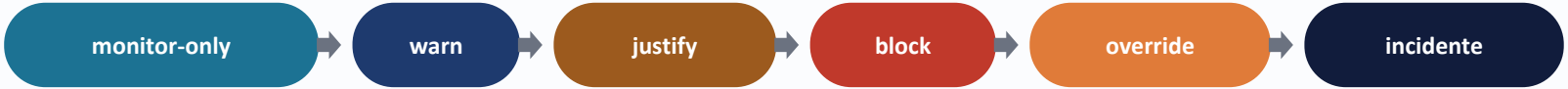
Una regla ve 16 dígitos. ¿Qué son?

- **PAN real**
- identificador ficticio
- un hash
- código de prueba
- dato público

El valor está en combinar

Content + Classification + User + Device + Destination + Business context + Behaviour

La política debe ser graduada, no solo «bloquear»



Un control técnicamente correcto falla si bloquea procesos legítimos. No todo dato sensible se trata igual.

BLOQUE B



Criptografía, claves y confianza

Propiedades cripto · gestión de claves · PKI/X.509 · TLS 1.3

Cifrado, hash, MAC y firma no son intercambiables



Cifrado

Confidencialidad

Reversible con la clave correcta.



Hash

Integridad

Irreversible; no hay «clave para descifrar SHA-256».



MAC / HMAC

Autenticidad + integridad

Con secreto compartido; sin no repudio entre las partes.



Firma digital

Integridad + autenticidad + evidencia

Firma con clave privada; se verifica con la pública.

Simétrico, asimétrico e híbrido

Simétrico

Misma clave para cifrar y descifrar. AES es la referencia.

Rápido, eficiente.
Problema: distribuir y proteger la clave.

Asimétrico

Par de claves: privada y pública. RSA y ECC son familias distintas.

Intercambio de claves, firma, autenticación, PKI.

Híbrido

Lo que usan los protocolos modernos.

Asimétrico → clave de sesión → cifrado simétrico.
No se cifra una sesión entera con RSA.

No es «RSA vs AES». El protocolo moderno negocia una clave con criptografía asimétrica y luego cifra los datos con simétrica, que es mucho más rápida. Cada familia hace su trabajo.

La criptografía se rompe alrededor de la clave



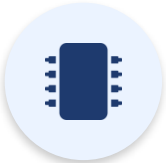
Cada fase necesita controles.

Dónde se rompe de verdad (no en el algoritmo):

- ✕ clave junto al dato
- ✕ permisos excesivos
- ✕ sin rotación
- ✕ sin owner
- ✕ private keys exportables
- ✕ secretos en Git
- ✕ claves sin inventario
- ✕ parámetros incorrectos

Crypto-agility: si no sabes dónde usas criptografía (certificados, algoritmos, librerías, claves, expiraciones), no podrás sustituirla cuando cambien los requisitos.

HSM, KMS y Vault resuelven problemas distintos



HSM

Protege operaciones y material criptográfico en hardware de alta protección.



KMS

Servicio de gestión de claves: generación, storage, versioning, policies, rotation, uso remoto.



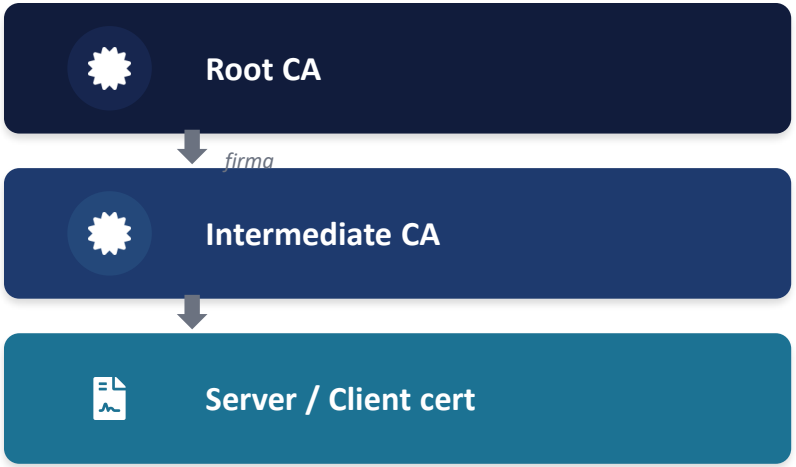
Secrets Vault

Gestiona secretos y el acceso a ellos (no solo claves criptográficas).



El producto concreto importa menos que el patrón de custodia y uso. La pregunta no es «¿qué HSM compro?», sino: ¿quién genera, quién accede, cómo se autentica, cuánto dura, cómo rota y cómo se registra su uso?

La confianza no viene de «tener una firma»



La confianza aparece porque…

- el verificador confía en una raíz
- la cadena puede validarse
- las firmas son correctas
- está en su periodo de validez
- el uso permitido es compatible
- el nombre/identidad coincide (SAN)
- no hay revocación relevante

SAN, revocación y qué NO demuestra un certificado

Subject Alternative Name

La identidad del servidor se valida contra SAN. Un certificado puede ser criptográficamente correcto y NO ser válido para el hostname pedido.

Revocación: CRL y OCSP

No es perfecta ni instantánea: disponibilidad, caching, privacidad, soft-fail, latencia. La revocación tiene límites operativos reales.

Un certificado válido NO demuestra que…

- ✗ la aplicación no tenga vulnerabilidades
- ✗ la CA nunca haya fallado
- ✗ la autorización sea correcta
- ✗ el servidor no esté comprometido
- ✗ la URL no fuera ya maliciosa

TLS protege el canal, no todo lo demás

Qué SÍ protege

- Confidencialidad e integridad en tránsito
- Autenticación del servidor
- Opcionalmente, autenticación mutua (mTLS)

Qué NO protege

- Endpoint comprometido
- Autorización defectuosa
- Datos antes/después del canal
- Errores lógicos · malware en cliente/servidor

TLS 1.3 y forward secrecy

Versión moderna de referencia. Separa la identidad de largo plazo de las claves de sesión efímeras: comprometer una clave no descifra sesiones pasadas.

Fallos a diagnosticar (Lab 4.1)

CA no confiable · hostname mismatch · certificado expirado · cadena incompleta · cipher incompatible · trust store equivocado · mTLS sin cert cliente

BLOQUE C



Identidad y accesos

IAM humano y de máquina · MFA · SAML/OAuth/OIDC · PAM · ZSP

IAM gobierna identidades humanas Y de máquina

Humanas

empleados · administradores · contractors

De máquina

service accounts · managed identities · workloads · dispositivos · API clients · bots/agentes

Las identidades de máquina suelen superar en número a las humanas — y se gobiernan peor.
Cuentas de servicio con privilegios permanentes, sin owner, sin rotación y sin caducidad son uno de los caminos de ataque más habituales. IAM moderno trata a máquinas y humanos con el mismo rigor.

Autenticar no es autorizar (ni auditar)



¿Quién/qué eres y qué evidencia aportas?

password · FIDO2/passkey · certificado · token · workload identity



¿Qué puedes hacer, sobre qué y bajo qué condiciones?

RBAC · ABAC · policy-based · ReBAC · ACL · scopes/claims



¿Qué acción se realizó realmente y con qué contexto?

Sin telemetría puedes autenticar y autorizar bien pero no investigar el abuso

MFA resistente a phishing y el problema de la sesión

OTP manual	Interceptable por phishing en tiempo real
Push	Sufre MFA fatigue
FIDO2 / WebAuthn / passkey	Autenticador ligado criptográficamente al origen esperado

MFA no elimina el robo de sesión

Aun con autenticación fuerte siguen existiendo: **robo de session cookie · token theft · malware en endpoint · abuso de sesión ya autorizada · OAuth consent abuse.**

Por eso hace falta: strong auth + session protection + token lifecycle + device/context + least privilege + telemetry. (NIST SP 800-63-4, jul-2025)

SAML, OAuth 2.0 y OpenID Connect



SAML

Federación / autenticación empresarial

Assertions XML. Roles: Identity Provider · Service Provider. No es «OAuth antiguo».



OAuth 2.0

Delegación de autorización

NO nació como login. Roles: resource owner · client · authorization server · resource server.



OpenID Connect

Capa de identidad sobre OAuth 2.0

Añade ID Token, UserInfo, discovery y claims de identidad. OIDC sí sirve para login.



OAuth es delegación de autorización; OIDC añade identidad. Usar OAuth «a pelo» como si fuera un protocolo de login es un antipatrón clásico y fuente de vulnerabilidades.

RFC 9700 (BCP 240, enero 2025)

Redirect URIs exactas

Compararlas de forma exacta salvo excepciones muy limitadas.

PKCE para public clients

Obligatorio; recomendado también para confidential clients.

Evitar open redirectors

Son un vector clásico de robo de código/token.

Sender-constrained tokens

Reducen el replay de tokens cuando proceda.

TLS extremo a extremo

Sin excepciones en el flujo de autorización.

Auth asimétrica de cliente

Preferirla cuando sea viable frente a client secrets.

OAuth 2.1 sigue en desarrollo a septiembre de 2026. No presentarlo como un RFC final: consolida buenas prácticas, pero aún no está cerrado.

De standing privilege a Zero Standing Privileges

El problema — standing privilege: alice ∈ Domain Admins, 24×7, 365 días/año. Aunque administre 20 min/semana, la exposición es permanente.

JIT

Just-in-Time

Privilegio cuando se necesita, por tiempo limitado, con aprobación, logging y revocación automática.

JEA

Just-Enough-Admin

No hace falta «admin completo»: quizá solo Restart-Service, no Full Administrator.

ZSP

Zero Standing Privileges

Eliminar el privilegio admin permanente y materializarlo dinámicamente. No es «nadie tiene privilegios».

BLOQUE D

Secretos y nube

Secrets lifecycle · workload identity · responsabilidad compartida · CSPM/CNAPP

Mover el secreto de sitio no lo protege

Antipatrón

```
DB_PASSWORD = "Telvora2026!"
```

Moverlo a un `.env` no arregla nada si acaba en Git, backups, imágenes o logs.

Lifecycle del secreto

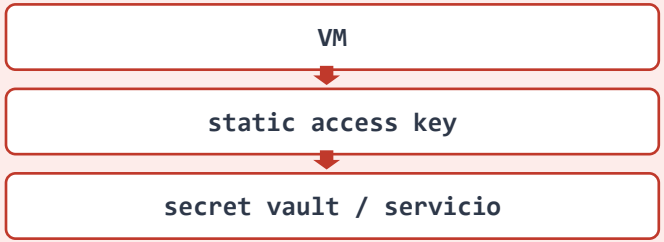


OWASP: los secretos deben ser de vida limitada, rotables, revocables, visibles solo para quien los necesita y nunca registrados en texto claro.

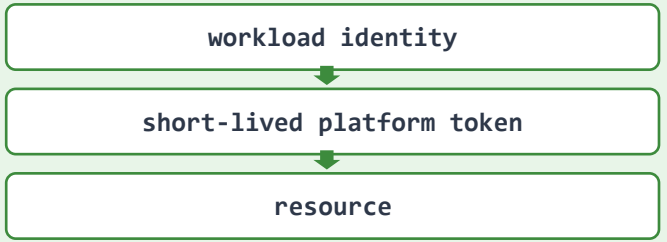
Vault ≠ seguridad automática. ¿Quién lee? ¿Quién cambia políticas? ¿Qué workload lo obtiene y cómo se autentica? ¿Cuánto dura? ¿Se cachea? ¿Se registra su valor sin querer?

Preferir identidad de workload a secretos estáticos

Antipatrón



Mejor patrón (cuando la plataforma lo permite)



Reduce

- distribución manual
- copias accidentales
- secretos de larga duración
- rotación manual

No elimina el problema IAM: una identidad gestionada con permisos excesivos sigue siendo peligrosa.

La responsabilidad compartida cambia por servicio

IaaS

El cliente controla más capas

Cliente responsable de:
OS · middleware · runtime · red · IAM · workloads · datos

PaaS

El proveedor gestiona más plataforma

Cliente responsable de:
Cliente: identidades · config · datos · código · secretos · exposición · logging

SaaS

El proveedor gestiona casi todo

Cliente responsable de:
Cliente: usuarios · MFA · roles · sharing · retención · OAuth apps · data governance

En los tres modelos, identidades, configuración y datos son SIEMPRE del cliente. Cuanto más «gestionado» el servicio, más se concentra tu responsabilidad en identidad y configuración — justo donde ocurren las brechas.

CSPM y CNAPP: la herramienta ve, el analista interpreta

CSPM

Detecta desviaciones de posture:

- exposición pública
- cifrado ausente
- logging deshabilitado
- IAM excesivo

CNAPP

Integra (como concepto de mercado): posture + workload protection + entitlement + IaC/supply chain.

No es una garantía: evalúa capacidades concretas.

El scanner encuentra un puerto abierto. El analista interpreta por qué existe, qué protege, qué activo expone y cuál es el attack path.

La herramienta responde «¿cumple la regla?». No responde «¿es esta arquitectura adecuada para este escenario de riesgo?». Esa pregunta es humana.

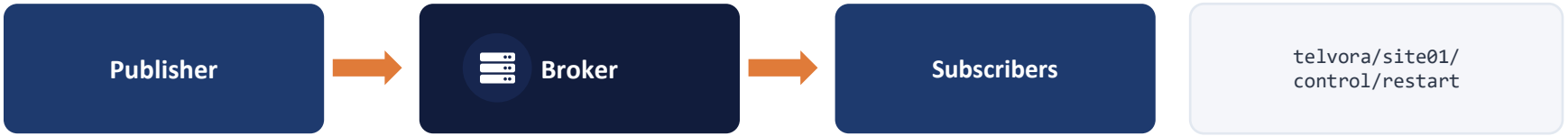
BLOQUE E



IoT y confianza

MQTT · modelo de amenaza · modelo de confianza de dispositivos

MQTT: de texto claro a confianza controlada



Riesgos frecuentes

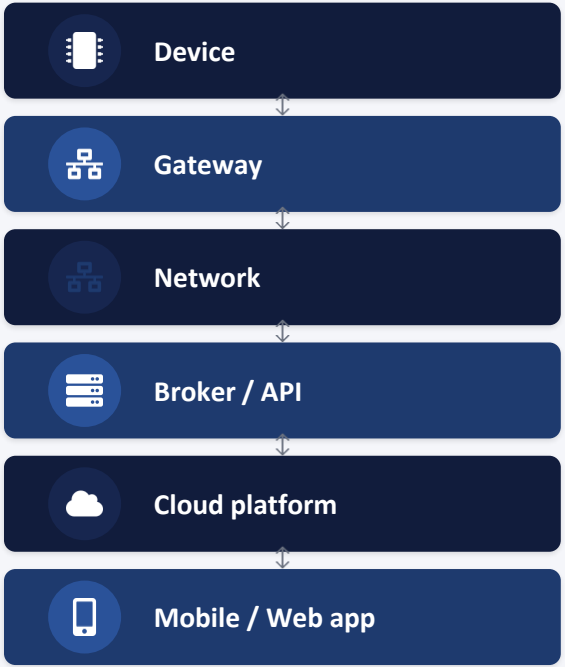
- ✕ acceso anónimo · credenciales débiles
- ✕ credenciales en claro sin TLS
- ✕ ACL inexistentes
- ✕ wildcard subscriptions excesivas
- ✕ publicación en topics de control
- ✕ broker expuesto a Internet

TLS no sustituye a las ACL

Un dispositivo autenticado que puede publicar en telvora/# tiene el canal cifrado… y abuso total autorizado.

- ✓ **Identity**
- ✓ **+ TLS**
- ✓ **+ Topic-level ACL**
- ✓ **+ Network restriction**
- ✓ **+ Device lifecycle**
- ✓ **+ Monitoring**

Modelo de confianza de un sistema IoT



IoT seguro exige cinco dimensiones

- **Identidad:** de dispositivo, no credenciales compartidas
- **Lifecycle:** firmware, actualización, aprovisionamiento y baja
- **Red:** segmentación y restricción de exposición
- **Aplicación:** ACL, autorización y validación de mensajes
- **Monitorización:** telemetría y detección de abuso

Dos microchallenges y cuatro laboratorios

4.A — «Está cifrado, ¿está protegido?» · **4.B — OAuth/OIDC Security Review**

Lab 4.1
PKI & TLS Trust Investigation

CA de laboratorio, emisión de certificado, validación de cadena, SAN y diagnóstico de errores TLS.

Lab 4.2
IAM Privilege & Identity Audit

Auditar AD/Telvora: standing privilege, cuentas obsoletas, service accounts y group nesting.

Micro-lab 4.C
Secret Exposure Drill

Repo Git con secretos: descubrir, medir impacto, rotar/revocar y mejorar el diseño.

Lab 4.3
MQTT: Cleartext → Controlled Trust

Broker inseguro, captura Wireshark, endurecer con TLS + auth + ACL y segunda captura.

Todo desemboca en la Mission 04 — Data & Identity Security Review: informe de 3 páginas con clasificación, top-5 riesgos, debilidades y 5 controles priorizados con su evidencia.

Mensajes para no olvidar

Data security ≠ encryption

Proteger el valor y el contexto, no solo cifrar el fichero.

La cripto se rompe en las claves

Y en los protocolos y parámetros, no en el algoritmo.

Certificado válido ≠ app segura

TLS protege el canal; no corrige ACL ni lógica.

AuthN ≠ AuthZ · MFA ≠ anti-robo

OAuth delega autorización; OIDC añade identidad.

Standing privilege = exposición

El mejor secreto persistente es el que no hace falta crear.

Todo control produce evidencia

IoT exige identidad, lifecycle, red, app y monitorización.

✓ MÓDULO 4 COMPLETADO

FIN DEL BLOQUE I — CIBERSEGURIDAD

A continuación

Bloque II — Ciberinteligencia

- De proteger identidades y datos… a entender a los adversarios
- OSINT, threat intelligence y análisis de actores
- Del dato defensivo al dato como fuente de inteligencia

«Hemos aprendido a proteger. Ahora aprenderemos a conocer al adversario.»